

Feature Engineering Report

Telemetry for ML-Based Threat Detection

Author: Abdul Rehman

Assignment: Task 01 - Feature Engineering Report

Context: ARZENS Security Engineering Internship

Date: July 2026

CONFIDENTIAL - FOR ACADEMIC PURPOSES ONLY

Table of Contents

1 Executive Summary

2 Introduction

3 Engineered Security Features

- 3.1 Failed Login Ratio
- 3.2 Login Frequency
- 3.3 Geo-Velocity (Impossible Travel)
- 3.4 Session Duration Anomaly
- 3.5 Port Scan Index
- 3.6 DNS Query Entropy
- 3.7 Data Exfiltration Volume
- 3.8 Privilege Escalation Score
- 3.9 Off-Hours Activity Ratio
- 3.10 Connection Burstiness

4 Privacy-Aware Feature Engineering

- 4.1 Pseudonymization
- 4.2 k-Anonymity
- 4.3 Differential Privacy

5 Feature Selection Strategy

- 5.1 Mutual Information
- 5.2 Chi-Squared Test
- 5.3 Pearson and Spearman Correlation
- 5.4 Variance Threshold Filtering

6 Conclusion

1. Executive Summary

This report provides a comprehensive overview of feature engineering strategies designed for Machine Learning (ML)-based threat detection systems. The objective is to outline ten key security features derived from various security telemetry sources, detailing their mathematical definitions, security detection purposes, data requirements, privacy risks, and corresponding mitigation strategies.

Furthermore, this document explores critical concepts in privacy-aware feature engineering, including pseudonymization, k-anonymity, and differential privacy, ensuring that threat detection capabilities do not compromise user privacy or violate compliance requirements. Finally, a robust feature selection strategy is detailed to optimize model performance, prevent overfitting, and reduce computational overhead by applying techniques such as Mutual Information, Chi-Squared tests, and Correlation Analysis.

2. Introduction

In modern cybersecurity operations, the sheer volume of telemetry generated by endpoints, networks, and cloud environments makes manual threat hunting and rule-based detection insufficient. Machine Learning (ML) models are increasingly deployed to identify complex, anomalous, or subtle attack patterns. However, the efficacy of an ML model is intrinsically tied to the quality of the data it ingests. Feature engineering -- the process of transforming raw data into meaningful variables that highlight underlying patterns -- is essential.

When engineering features from security telemetry (e.g., authentication logs, network flow data, endpoint telemetry), organizations must balance the need for high-fidelity detection signals with the obligation to protect sensitive user information. This report systematically details 10 engineered features, assessing their mathematical basis, detection utility, and privacy implications, followed by strategies for privacy preservation and feature optimization.

3. Engineered Security Features

3.1 Failed Login Ratio

Mathematical Definition

The Failed Login Ratio (FLR) for a user u within a specific time window w is defined as the number of failed login attempts divided by the total number of login attempts (both successful and failed):

$$FLR(u,w) = \text{failed_logins}(u,w) / \text{total_logins}(u,w)$$

Security Detection Purpose

This feature is highly indicative of brute-force attacks, password spraying, and credential stuffing. A high ratio suggests that an attacker is attempting to guess passwords or using automated tools to compromise an account.

Required Data Sources

- Authentication Logs (Active Directory, IAM, SSO platforms)

- VPN/Proxy access logs

Privacy Risk Assessment

Risk Level: Medium

Justification: While it does not expose exact passwords, it reveals user behavioral patterns and login habits. Continual tracking of specific user accounts can indirectly build a profile of user activity.

Mitigation Strategy

- Aggregate data over broader time windows.
- Hash user identifiers so that the analysis is performed on pseudonymous tokens rather than explicit usernames.

3.2 Login Frequency

Mathematical Definition

Login Frequency (LF) represents the rate of logins for a user u over a specified time window w (e.g., hours):

$$LF(u, w) = \text{count}(\text{login_events}(u)) / \text{window_hours}(w)$$

Security Detection Purpose

Detects account abuse, compromised credentials, and anomalous access patterns. Scripts, automated bots, or an attacker establishing persistence often generate a higher frequency of logins than a standard human user.

Required Data Sources

- Authentication Logs
- Identity and Access Management (IAM) systems

Privacy Risk Assessment

Risk Level: Medium

Justification: Reveals precise times when an individual is active or inactive, which can infer working hours, time zones, and personal habits.

Mitigation Strategy

- Implement timestamp rounding (e.g., to the nearest 15 or 30 minutes) to reduce temporal precision.
- Use anomaly scoring based on baselines rather than storing raw frequencies long-term.

3.3 Geo-Velocity (Impossible Travel)

Mathematical Definition

Geo-Velocity (GV) measures the speed required to travel between two consecutive login locations ($loc1$, $loc2$) at times $t1$ and $t2$. It relies on the Haversine formula to compute the great-circle distance. An alert is typically generated if $GV(u) > 800$ km/h (commercial flight speed):

$$\begin{aligned} a &= \sin^2(d_phi/2) + \cos(phi1) * \cos(phi2) * \sin^2(d_lambda/2) \\ c &= 2 * \text{atan2}(\text{sqrt}(a), \text{sqrt}(1-a)) \\ \text{distance} &= R * c \quad (R = 6371 \text{ km}) \end{aligned}$$

$$GV(u) = \text{distance} / (t2 - t1)$$

Security Detection Purpose

Identifies 'impossible travel' scenarios, strongly suggesting that credentials have been compromised and are being used simultaneously or sequentially by an attacker in a different geographical location.

Required Data Sources

- Authentication Logs
- GeoIP Databases (e.g., MaxMind)

Privacy Risk Assessment

Risk Level: HIGH

Justification: Processing exact IP addresses and mapping them to physical geographical coordinates explicitly tracks a user's physical movements and locations.

Mitigation Strategy

- Mask IP addresses by zeroing the last octet (e.g., 192.168.1.0/24) before geolocation.
- Process geolocation locally and only output a binary `is_impossible_travel` flag to the ML pipeline, discarding the raw coordinate data.

3.4 Session Duration Anomaly

Mathematical Definition

The Session Duration Anomaly (SDA) calculates the standard score (Z-score) of a current session's duration relative to the user's historical baseline mean and standard deviation:

$$SDA(s) = (\text{duration}(s) - \mu_{\text{user}}) / \sigma_{\text{user}}$$

Security Detection Purpose

Detects Command and Control (C2) beaconing, long-standing unauthorized remote access, or session hijacking. Attackers often maintain persistent connections that fall far outside standard human interaction durations.

Required Data Sources

- Web Server Logs
- VPN/Proxy Logs
- NetFlow records

Privacy Risk Assessment

Risk Level: Medium

Justification: Tracks exact start and end times of user activity, which can model employee productivity and behavior in potentially invasive ways.

Mitigation Strategy

- Store only the statistical aggregates (mean, std) instead of every individual session length.
- Standardize durations into categorical bins (e.g., 'short', 'medium', 'long') instead of exact millisecond

values.

3.5 Port Scan Index

Mathematical Definition

The Port Scan Index (PSI) evaluates the breadth of destination ports accessed by a source IP over a time window w . It is often paired with a Connection Failure Ratio:

```
PSI(ip,w) = unique_dest_ports(ip,w) / window_seconds  
ConnFailRatio = RST_packets / SYN_packets
```

Security Detection Purpose

Identifies reconnaissance phases of an attack. A high PSI paired with a high ConnFailRatio strongly indicates horizontal or vertical network scanning (e.g., Nmap activity).

Required Data Sources

- NetFlow / IPFIX
- Firewall / Router Logs

Privacy Risk Assessment

Risk Level: Low

Justification: Network port connections are generally machine-to-machine interactions and do not typically expose sensitive PII, unless tied directly to a single-user endpoint without IP masking.

Mitigation Strategy

- Aggregate data at the subnet level rather than tracking individual internal IPs.
- Limit data retention to short rolling windows (e.g., 24 hours).

3.6 DNS Query Entropy

Mathematical Definition

Calculates the Shannon Entropy $H(X)$ of the character distribution in a queried DNS domain string to measure its randomness. Normal domains generally score between 2.0 and 3.0, while suspicious domains score $> 3.5 - 4.2$:

```
 $H(X) = - \sum ( p(x_i) * \log_2(p(x_i)) )$ 
```

Security Detection Purpose

Highly effective for identifying Domain Generation Algorithms (DGA) used by malware for C2 communication, as well as detecting DNS tunneling where data is exfiltrated in subdomains.

Required Data Sources

- DNS Resolver Logs
- Passive DNS captures

Privacy Risk Assessment

Risk Level: Medium

Justification: DNS logs reveal a user's web browsing history, which can expose personal interests, medical inquiries, or affiliations.

Mitigation Strategy

- Only evaluate entropy on domains that are NOT in a known-good top 1 million list (e.g., Tranco/Alexa).
- Hash the source IP making the query so the query itself cannot be tied back to an individual user.

3.7 Data Exfiltration Volume

Mathematical Definition

Data Exfiltration Volume (DEV) compares the volume of outbound bytes from a host h over window w against a historical baseline. It is often paired with an Upload/Download ratio:

$$\text{DEV}(h,w) = \text{bytes_out}(h,w) / \text{baseline_bytes}(h)$$
$$\text{UploadDownloadRatio} = \text{bytes_out}(h,w) / \text{bytes_in}(h,w)$$

Security Detection Purpose

Critical for detecting data breaches, insider threats, and malware exfiltrating intellectual property or sensitive databases to external servers.

Required Data Sources

- NetFlow / Proxy Logs
- Data Loss Prevention (DLP) Systems
- EDR (Endpoint Detection and Response)

Privacy Risk Assessment

Risk Level: Medium

Justification: Volume alone is less sensitive than payload data, but monitoring individual endpoint upload activity can profile user work habits.

Mitigation Strategy

- Monitor byte counts without inspecting payload contents (Deep Packet Inspection requires separate privacy controls).
- Establish baselines per departmental group rather than per individual user.

3.8 Privilege Escalation Score

Mathematical Definition

The Privilege Escalation Score (PES) aggregates weighted privilege change events for a user u over window w . Each event type (e.g., added to Admin group, modifying ACLs) is assigned a risk weight:

$$\text{PES}(u,w) = \text{SUM}(\text{weight}(\text{priv_change_events}))$$

Security Detection Purpose

Detects attackers attempting to elevate their access rights after initial compromise, as well as malicious insider threats modifying permissions to access restricted assets.

Required Data Sources

- Active Directory / LDAP Audit Logs
- IAM configuration logs

Privacy Risk Assessment

Risk Level: Medium

Justification: Pertains heavily to user roles and organizational hierarchy.

Mitigation Strategy

- Use Role-Based Access Control (RBAC) abstraction instead of logging exact username changes.
- Ensure audit logs are heavily restricted and only visible to authorized security personnel.

3.9 Off-Hours Activity Ratio

Mathematical Definition

The Off-Hours Activity Ratio (OAR) calculates the proportion of events occurring outside standard operational hours (e.g., 8 AM - 6 PM local time) against total events:

$$\text{OAR}(u, w) = \text{events_offhours}(u, w) / \text{total_events}(u, w)$$

Security Detection Purpose

Detects compromised accounts or insider threats operating when the target organization is least monitored. Attackers often prefer off-hours to avoid triggering immediate response from SOC analysts.

Required Data Sources

- Authentication Logs
- Endpoint Telemetry

Privacy Risk Assessment

Risk Level: Low

Justification: Aggregates time-based behavior without exposing specific actions or locations.

Mitigation Strategy

- Use broad time categories (e.g., 'Business', 'Evening', 'Night') instead of precise timestamps.
- Adjust 'off-hours' baselines dynamically per user to account for varying global schedules.

3.10 Connection Burstiness

Mathematical Definition

Connection Burstiness (CB) measures the volatility of connection rates by dividing the maximum connection rate in a micro-window by the average rate over the broader window:

$$\text{CB}(ip, w) = \text{max_rate}(\text{sub_window}) / \text{avg_rate}(\text{window})$$

Security Detection Purpose

Detects automated activity such as DDoS attacks, fast-flux botnets, or rapid vulnerability scanning, which exhibit sudden spikes in traffic that smooth out over longer averages.

Required Data Sources

- NetFlow
- Firewall Logs

Privacy Risk Assessment

Risk Level: Low

Justification: Focuses entirely on network transmission physics (packet rates) and does not inspect application-layer data or PII.

Mitigation Strategy

- Process burstiness at the edge (e.g., on the router/switch) and only forward the metadata metric to the SIEM.
- Avoid centralizing all raw packet data; work with summarized metrics.

4. Privacy-Aware Feature Engineering

Feature engineering for security often relies on telemetry containing Personally Identifiable Information (PII). Implementing privacy-aware engineering techniques ensures compliance with regulations like GDPR and CCPA while maintaining model efficacy.

4.1 Pseudonymization

Pseudonymization replaces identifying fields with artificial identifiers. Unlike anonymization, it is reversible with the right key.

Techniques:

- Hashing: Applying SHA-256 to user IDs or email addresses. Crucially, a salt (a secret random string) must be appended before hashing ($\text{Hash}(\text{Salt} + \text{UserID})$) to prevent dictionary attacks or rainbow table lookups.
- IP Masking: Truncating or zeroing out the last octet of an IPv4 address (e.g., 192.168.1.155 becomes 192.168.1.0/24). This preserves network topology data for ML while obscuring the specific endpoint.
- Timestamp Rounding: Modifying exact timestamps to the nearest hour or 15-minute block to prevent exact behavioral profiling.

4.2 k-Anonymity

A dataset achieves k-anonymity if the information for each person contained in the release cannot be distinguished from at least k-1 individuals whose information also appears in the release.

Techniques:

- Generalization: Broadening specific values (e.g., replacing exact ages with age ranges like 20-30, or IP addresses to subnets).
- Suppression: Removing entirely rare or unique outlier values from the dataset to prevent them from acting as identifiers.

Limitations and Supplements:

- Vulnerable to the homogeneity attack (where all k individuals share the same sensitive attribute) and the background knowledge attack.
- l-diversity: Ensures sensitive values within the k-group are diverse.
- t-closeness: Ensures the distribution of sensitive attributes in the group matches the global distribution.

4.3 Differential Privacy

Differential privacy provides a mathematical guarantee that the inclusion or exclusion of a single record will not significantly affect the outcome of any statistical query on the dataset.

Laplace Mechanism:

```
noise ~ Laplace(0, sensitivity / epsilon)
```

Where sensitivity (Δf) is the maximum change one record can cause, and epsilon is the privacy budget.

Core Guarantee:

$$P(M(D) \text{ in } S) \leq e^{\epsilon} \cdot P(M(D') \text{ in } S)$$

Where D and D' are datasets differing by one record, and M is the randomized algorithm.

Epsilon Guidelines:

- $\epsilon \leq 1.0$: Strong privacy protection.
- $1.0 < \epsilon \leq 10$: Moderate protection.
- $\epsilon > 10$: Weak protection, heavily favoring data utility over privacy.

Application:

Useful for aggregated features (e.g., adding Laplacian noise to the global count of failed logins per department before feeding it to an anomaly detection model).

5. Feature Selection Strategy

Feeding all engineered features into an ML model can lead to the 'curse of dimensionality,' overfitting, and excessive computational latency. A structured feature selection strategy is mandatory.

5.1 Mutual Information

Mutual Information (MI) measures the reduction in uncertainty for one variable given the knowledge of another. Unlike basic correlation, MI captures non-linear relationships.

$$I(X;Y) = \sum (p(x,y) \cdot \log(p(x,y) / (p(x) \cdot p(y))))$$

Application: Used to evaluate the dependency between an engineered feature (e.g., PSI) and the target label (e.g., `is_malicious`). Features with an MI score near zero are discarded.

5.2 Chi-Squared Test

The Chi-Squared test assesses the independence of two categorical variables.

$$\chi^2 = \sum (O_{ij} - E_{ij})^2 / E_{ij}$$

Where O is the observed frequency and E is the expected frequency. Best used for categorical features, such as comparing the frequency of categorical alert levels (High/Med/Low) against threat presence.

5.3 Pearson and Spearman Correlation

Correlation matrices help identify and eliminate redundant features.

- Pearson: Measures linear correlation between continuous variables.
- Spearman: Measures monotonic relationships using rank order (more robust to outliers).

Application: If two features (e.g., Failed Login Ratio and Total Failed Logins) exhibit a correlation threshold > 0.9 , one

should be eliminated (redundancy elimination) to reduce multicollinearity.

5.4 Variance Threshold Filtering

This unsupervised approach removes features whose variance falls below a specific threshold. If a feature like Geo-Velocity evaluates to 0 for 99.9% of internal LAN traffic, its variance is near zero. While theoretically useful, if the data is entirely uniform, the ML model gains no discriminative power from it, and it can be filtered out during preprocessing to save compute resources.

6. Conclusion

Engineering robust features from security telemetry is a delicate balance between generating highly discriminative signals for ML algorithms and adhering strictly to privacy-preserving doctrines. The ten features defined in this report -- spanning authentication, network flow, and DNS monitoring -- provide a foundational matrix for identifying both automated bot activity and sophisticated human-led incursions.

By applying advanced feature selection protocols like Mutual Information and variance filtering, security teams can streamline ML pipelines. Concurrently, embedding mechanisms like salted hashing, differential privacy, and k-anonymity ensures that the pursuit of security does not come at the cost of individual privacy.

This report serves as both a technical reference and a practical guide for security engineers seeking to build privacy-preserving, ML-ready feature pipelines from raw security telemetry data.